

Plano de Respostas aos Riscos

Projeto: Arkanis - grupo 1

Nome dos Integrantes: Aleff Silva, João Colombo, Luciano Reis e

Matheus Zimmer

Data: 10/05/2025

Versão: 1.0.0

1. Introdução

Este documento detalha as estratégias e ações específicas planejadas para lidar com os riscos identificados no projeto Projeto1 – Entrega 2. O objetivo é aumentar as oportunidades (riscos positivos) e reduzir ou eliminar as ameaças (riscos negativos) aos objetivos do projeto. Este plano deve ser utilizado e atualizado continuamente pela equipe do projeto.

A análise de riscos foi realizada com apoio da ferramenta Aikido Security, utilizada para identificar vulnerabilidades de segurança no frontend, backend, aplicativo mobile e firmware em C++ executado no ESP32. As vulnerabilidades encontradas foram analisadas e documentadas para definição das estratégias de resposta e mitigação.

A auditoria realizada no Aikido Security identificou conformidade com práticas de segurança relacionadas ao OWASP Top 10, análise de dependências, exposição de segredos e monitoramento de vulnerabilidades conhecidas. O relatório gerado pela ferramenta foi anexado separadamente como evidência da execução da análise.

2. Tabela de Respostas aos Riscos

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
TEC-001	Dependências vulneráveis identificadas no frontend e backend pelo Aikido Security.	Alto	Mitigar	1. Atualizar bibliotecas vulneráveis.2. Realizar monitoramento contínuo de dependências.3. Implementar verificações automáticas de segurança no pipeline CI/CD.	Matheus Morais Zimmer - Especialista em Performance e Segurança DevOps	15/05/2026	Em Andamento
TEC-002	Possível exposição de credenciais e tokens sensíveis no código-fonte do projeto.	Extremo	Prevenir (Evitar)	1. Remover credenciais hardcoded.2. Utilizar variáveis de ambiente para armazenamento seguro.3. Configurar .gitignore para impedir envio de arquivos sensíveis.	Matheus Morais Zimmer - Especialista em Performance e Segurança DevOps	12/05/2026	Concluído
TEC-003	Falhas de validação de entrada podem permitir ataques de injeção na API backend.	Alto	Mitigar	1. Implementar sanitização de entradas.2. Validar parâmetros recebidos pelas APIs.3. Adicionar testes automatizados de segurança.	Aleff Silva Souza - Líder de Backend e Infraestrutura	20/05/2026	Em Andamento
TEC-004	Comunicação insegura entre o ESP32 e os serviços backend pode permitir interceptação de dados.	Médio	Mitigar	1. Implementar HTTPS/TLS na comunicação.2. Revisar autenticação dos dispositivos IoT.3. Validar certificados digitais utilizados.	Aleff Silva Souza - Líder de Backend e Infraestrutura	22/05/2026	Concluído

TEC-005	Dependências desatualizadas no aplicativo mobile podem conter vulnerabilidades conhecidas.	Médio	Mitigar	1. Atualizar pacotes e bibliotecas do aplicativo.2. Monitorar CVEs reportadas pelo Aikido.	João Paulo Souza Colombo - Líder de Mobile e Interface	18/05/2026	Concluído
TEC-006	APIs podem estar sem autenticação adequada, permitindo acesso indevido aos dados.	Crítico	Mitigar	1. Implementar autenticação JWT.2. Criar controle de autorização por perfil.3. Revisar permissões dos endpoints da API.	Aleff Silva Souza - Líder de Backend e Infraestrutura	20/05/2026	Em Andamento
TEC-007	Falta de rate limiting pode permitir ataques de força bruta e negação de serviço.	Alto	Mitigar	1. Implementar limitação de requisições por IP.2. Monitorar tráfego suspeito.3. Configurar bloqueio automático para excesso de tentativas.	Aleff Silva Souza - Líder de Backend e Infraestrutura	22/05/2026	Não Iniciado
TEC-008	Armazenamento inseguro de dados sensíveis no aplicativo mobile.	Alto	Prevenir (Evitar)	1. Utilizar armazenamento criptografado.2. Evitar salvar tokens em texto puro.3. Revisar permissões do aplicativo.	João Paulo Souza Colombo - Líder de Mobile e Interface	19/05/2026	Em Andamento
TEC-009	Comunicação do ESP32 sem criptografia pode permitir interceptação de comandos.	Alto	Mitigar	1. Implementar HTTPS/TLS.2. Configurar autenticação dos dispositivos IoT.3. Validar conexões seguras no firmware.	Aleff Silva Souza - Líder de Backend e Infraestrutura	25/05/2026	Concluído
TEC-010	Possível exposição de informações sensíveis em logs da aplicação.	Médio	Mitigar	1. Remover logs sensíveis.2. Mascaram informações críticas.3. Revisar políticas de logging da aplicação.	Aleff Silva Souza - Líder de Backend e Infraestrutura	17/05/2026	Em Andamento
TEC-011	Configuração incorreta de CORS pode permitir acessos indevidos	Médio	Mitigar	1. Restringir origens autorizadas.2. Revisar políticas de acesso.3. Validar requisições	Aleff Silva Souza - Líder de Backend e Infraestrutura	18/05/2026	Não Iniciado

	à API.			externas.			
TEC-012	Falta de atualização contínua do firmware ESP32 pode deixar dispositivos vulneráveis.	Médio	Melhorar (ou Realçar)	1. Criar política de atualização do firmware.2. Implementar o versionamento do firmware.3. Monitorar vulnerabilidades relacionadas ao ESP32.	Aleff Silva Souza - Líder de Backend e Infraestrutura	28/05/2026	Não Iniciado
TEC-013	Upload de arquivos sem validação pode permitir envio de arquivos maliciosos.	Alto	Mitigar	1. Validar extensão dos arquivos.2. Limitar tamanho permitido.3. Verificar conteúdo dos uploads antes do processamento.	Aleff Silva Souza - Líder de Backend e Infraestrutura	21/05/2026	Em Andamento
EXT-001	Repositório público pode expor informações internas do sistema.	Médio	Prevenir (Evitar)	1. Revisar permissões do GitHub.2. Remover informações sensíveis do repositório.3. Monitorar a exposição de segredos no versionamento.	Matheus Moraes Zimmer - Especialista em Performance e Segurança DevOps	16/05/2026	Concluído
GER-001	Ausência de monitoramento contínuo de vulnerabilidades no projeto.	Médio	Mitigar	1. Integrar o Aikido Security ao pipeline CI/CD.2. Automatizar geração de alertas.3. Criar rotina de revisão semanal de segurança.	Luciano Reis Massaro - Gerente de Projeto	25/05/2026	Não Iniciado
OPP-001	Integração do Aikido Security ao pipeline CI/CD pode automatizar a detecção de vulnerabilidades antes do deploy.	Alto	Explorar (Oportunidade)	1. Integrar o Aikido ao GitHub Actions.2. Configurar análises automáticas a cada push.3. Bloquear deploys com vulnerabilidades críticas.	Matheus Moraes Zimmer - Especialista em Performance e Segurança DevOps	30/05/2026	Em Andamento
OPP-002	Uso de variáveis de ambiente centralizadas pode melhorar a segurança e	Médio	Melhorar (ou Realçar)	1. Centralizar segredos em arquivos .env.2. Documentar configuração segura do ambiente.3. Padronizar	Matheus Moraes Zimmer - Especialista em Performance e Segurança	18/05/2026	Concluído

	manutenção do sistema.			gerenciamento de credenciais.	DevOps		
OPP-003	Implementação de autenticação JWT pode aumentar a segurança das APIs e escalabilidade do sistema.	Alto	Explorar (Oportunidade)	1. Implementar autenticação JWT.2. Criar middleware de autorização.3. Adicionar expiração automática de tokens.	Aleff Silva Souza - Líder de Backend e Infraestrutura	25/05/2026	Em Andamento
OPP-004	Atualização contínua das dependências pode reduzir futuras vulnerabilidades no sistema.	Médio	Melhorar (ou Realçar)	1. Criar rotina mensal de atualização.2. Monitorar CVEs automaticamente.3. Revisar pacotes não utilizados.	Matheus Moraes Zimmer - Especialista em Performance e Segurança DevOps	Contínuo	Em Andamento
OPP-005	Implementação de HTTPS/TLS no ESP32 pode aumentar a confiabilidade e segurança da comunicação IoT.	Alto	Explorar (Oportunidade)	1. Configurar certificados digitais.2. Implementar comunicação criptografada.3. Validar conexões seguras no firmware.	Aleff Silva Souza - Líder de Backend e Infraestrutura	28/05/2026	Concluído
GER-002	Padronização das práticas de segurança pode melhorar a qualidade do desenvolvimento da equipe.	Médio	Compartilhar	1. Criar documentação de boas práticas.2. Compartilhar conhecimento entre frontend, backend e mobile.3. Realizar revisões periódicas de segurança.	Luciano Reis Massaro - Gerente de Projeto	05/06/2026	Concluído
TEC-014	Possível falha de validação de payload MQTT pode permitir dados inválidos, leituras incorretas ou inconsistências no banco de dados.	Médio	Mitigar	1. Validar campos obrigatórios do payload MQTT.2. Rejeitar valores inválidos ou fora do padrão esperado.3. Registrar payloads inválidos nos logs da aplicação.4. Criar respostas padronizadas para mensagens inválidas.	Aleff Silva Souza - Líder de Backend e Infraestrutura	24/05/2026	Em Andamento

TEC-015	Publicação MQTT não autorizada pode permitir envio de leituras falsas e geração incorreta de alertas no sistema.	Alto	Mitigar	1. Configurar autenticação segura no broker MQTT.2. Validar device_id e tópicos MQTT no backend.3. Restringir permissões por tópico MQTT.4. Monitorar divergências entre dispositivo e tópico publicado.	Aleff Silva Souza - Líder de Backend e Infraestrutura	26/05/2026	Em Andamento
EXT-002	Indisponibilidade do backend hospedado no Render ou perda de dados do SQLite após reinicialização pode afetar a continuidade operacional do sistema.	Médio	Mitigar	1. Documentar limitações do SQLite em ambiente produtivo.2. Planejar migração para PostgreSQL gerenciado.3. Criar rotina de backup/exportação de dados.4. Implementar monitoramento de disponibilidade da API.	Matheus Moraes Zimmer - Especialista em Performance e Segurança DevOps	30/05/2026	Não Iniciado
TEC-016	Uso de credenciais administrativas fracas ou ausência de MFA pode permitir acesso indevido ao sistema.	Alto	Mitigar	1. Definir política mínima de senha.2. Bloquear uso de credenciais fracas.3. Alterar senhas administrativas padrão.4. Avaliar implementação futura de MFA para administradores.	Matheus Moraes Zimmer - Especialista em Performance e Segurança DevOps	27/05/2026	Não Iniciado
TEC-017	Ausência de trilha completa de auditoria pode dificultar a identificação de alterações críticas e incidentes de segurança.	Médio	Mitigar	1. Registrar eventos críticos da aplicação.2. Vincular logs a usuário, data e operação realizada.3. Monitorar alterações administrativas e acessos sensíveis.4. Revisar periodicamente logs críticos do sistema.	Luciano Reis Massaro - Gerente de Projeto	29/05/2026	Em Andamento

TEC-018	Segredos expostos no histórico do Git podem continuar acessíveis mesmo após remoção do código-fonte atual.	Alto	Mitigar	1. Revisar histórico do GitHub em busca de credenciais antigas.2. Rotacionar credenciais previamente expostas.3. Remover segredos do versionamento utilizando ferramentas apropriadas.4. Manter varredura recorrente de secrets no Aikido Security.	Matheus Moraes Zimmer - Especialista em Performance e Segurança DevOps	23/05/2026	Em Andamento
---------	--	------	---------	---	--	------------	--------------

3. Detalhamento das Estratégias de Resposta

3.1. Estratégias para Ameaças (Riscos Negativos)

- **Prevenir (Evitar):** Consiste em modificar o ambiente ou o desenvolvimento do sistema para eliminar completamente a possibilidade da vulnerabilidade ocorrer.

Exemplo: Remoção de credenciais hardcoded do código-fonte e utilização de variáveis de ambiente (.env) para impedir exposição de informações sensíveis no repositório GitHub.

- **Transferir:** Consiste em transferir parte da responsabilidade do risco para serviços ou ferramentas terceiras especializadas em segurança e infraestrutura.

Exemplo: Utilização de plataformas de hospedagem com HTTPS/TLS nativo e serviços de monitoramento de vulnerabilidades fornecidos pelo Aikido Security. (Já concluído)

- **Mitigar:** Consiste em reduzir a probabilidade de exploração das vulnerabilidades e minimizar os impactos caso ocorram.

Exemplo: Atualização de dependências vulneráveis identificadas pelo Aikido Security, implementação de autenticação JWT, sanitização de entradas da API e validação de uploads de arquivos.

- **Aceitar:** Consiste em reconhecer a existência do risco sem realizar mudanças imediatas, normalmente quando o impacto é considerado baixo ou quando a correção será realizada futuramente.

Aceitação Ativa: Reservar tempo para futuras correções e monitoramento contínuo da vulnerabilidade.

Aceitação Passiva: Apenas monitorar o risco sem ação imediata.

3.2. Estratégias para Oportunidades (Riscos Positivos)

- **Explorar:** Aplicar ações para garantir que melhorias de segurança sejam implementadas e tragam benefícios ao projeto.

Exemplo: Integração do Aikido Security ao pipeline CI/CD para automatizar a detecção de vulnerabilidades antes dos deploys.

- **Melhorar (ou Realçar):** Aumentar a chance de melhorias contínuas na segurança e qualidade do software.

Exemplo: Implementação de testes automatizados de segurança e atualização contínua das dependências do sistema.

- **Compartilhar:** Distribuir conhecimento e responsabilidades de segurança entre os membros da equipe.

Exemplo: Criação de documentação de boas práticas de segurança e compartilhamento de conhecimento entre frontend, backend, mobile e IoT.

- **Aceitar:** Reconhecer oportunidades futuras sem implementação imediata.

Exemplo: Possibilidade futura de adoção de ferramentas avançadas de monitoramento contínuo de segurança conforme expansão do projeto.

4. Monitoramento e Revisão

Este plano será/foi revisado semanalmente durante o desenvolvimento do projeto, utilizando os resultados das análises realizadas no Aikido Security para acompanhar vulnerabilidades identificadas no frontend, backend, aplicativo mobile e firmware do ESP32.

O campo “Status” será atualizado continuamente para refletir o progresso das ações planejadas, podendo assumir os estados:

- Não Iniciado
- Em Andamento
- Concluído
- Cancelado

Novas análises de segurança serão executadas periodicamente para identificar:

- vulnerabilidades em dependências;
- exposição de credenciais;
- falhas de autenticação;
- configurações inseguras;
- riscos relacionados à comunicação IoT;
- vulnerabilidades conhecidas (CVEs).

Conforme o projeto evoluir, novos riscos poderão ser adicionados e riscos existentes poderão ser reavaliados de acordo com alterações no código-fonte, atualizações de bibliotecas, mudanças na infraestrutura e implementação de novas funcionalidades.

Além disso, a equipe realizará revisões contínuas das práticas de segurança adotadas no projeto, buscando reduzir vulnerabilidades, melhorar a proteção dos dados e manter a conformidade com boas práticas de desenvolvimento seguro.

5. Mitigações Implementadas no Código

- Atualização de dependências vulneráveis identificadas pelo Aikido Security.
- Remoção de credenciais expostas diretamente no código-fonte.
- Implementação de validação de entrada em endpoints da API.
- Revisão de permissões e autenticação do backend.
- Configuração de variáveis de ambiente para armazenamento seguro de segredos.
- Planejamento de uso de HTTPS/TLS na comunicação do ESP32.

6. Conclusão

A execução da auditoria de segurança no Aikido permitiu identificar riscos relevantes no projeto e definir ações corretivas para redução da superfície de ataque. As mitigações aplicadas aumentam a segurança do sistema e contribuem para a conformidade com boas práticas de desenvolvimento seguro.

7. Evidências Anexadas

- Relatório PDF gerado pelo Aikido Security.
- Código-fonte atualizado com as mitigações implementadas.